



Kiln V1 Bounty

 @kilnfi

Live



Total reward

\$1,000,000

 No deposit required

Findings submitted

307

Start date

9 Sep 2024

☐ I agree to our [Terms of Bounties](#), which govern my participation in the bounty.

Join bounty

 Instructions

Kiln On-Chain (v1) enables non-custodial platforms to propose an ETH staking offer where users can stake on dedicated validators while remaining the only one able to access their staked assets. The goal of these Ethereum Smart Contracts is to enable:

- Operator to register its validation keys deposit data on the Smart Contract
- Users to deposit on approved and available validation keys
- Manage the Execution and Consensus Layer rewards and exited ETH

- Perform the commission dispatching on these ETH when user performs a withdrawal action

This Bug Bounty is focused on the Staking Smart Contracts only, all items regarding dApps or validation infrastructure are out of scope.

For more information about Kiln On-Chain, please visit <https://www.kiln.fi/> Kiln provides rewards in USDC. For more details about the payment process, please view the Rewards & Severity Levels below

Smart Contracts in Scope

Smart Contract	Link
Consensus Layer Fee Dispatcher	0x462Dd07A79e5DDfBe0C171449C5c01788d5d03C3
Consensus Layer Fee Dispatcher (testnet)	0xD36B422a7EE65219732724d849B8b6BceD6155Fe
Consensus Layer Fee Dispatcher Proxy	0xE8EC6F702D68ded71112031D78bBFf959c7234C7
Consensus Layer Fee Dispatcher Proxy (testnet)	0x50DBa42662FD69f5Fd9236540aaD9f99f7F6b3b2
Execution Layer Fee Dispatcher	0xca4DD914fA713214844c84F153A5e1627536a7fC
Execution Layer Fee Dispatcher (testnet)	0xa69dDEBd0B6893A6F3d34A5df610d0E2ED433D18
Execution Layer Fee Dispatcher Proxy	0x72b4C52f18f52EbA3E4290a002dF7c387427b058
Execution Layer Fee Dispatcher Proxy (testnet)	0x639d818639B85a1892Bfbb40Bd724b4Ddea43C0C
Fee Recipient	0x933fBfeb4Ed1F11D12A39c2aB48657e6fc875C6
Fee Recipient (testnet)	0x1AcD717aDF8A3A1e4c23C6510cfbE76834E3f1bf
Staking Contract	0x0A7272e8573aea8359FEC143ac02AED90F822bD0
Staking Contract (testnet)	0xcd01846F1b37aCE16916969989C136e3c52ef7d2
Staking Contract Proxy	0x1e68238ce926dec62b3fbc99ab06eb1d85ce0270
Staking Contract Proxy (testnet)	0xe8Ff2a04837aac535199eEcB5ecE52b2735b3543

All code of Kiln can be found at

- <https://github.com/kilnfi/staking-contracts>

Documentation for the assets provided in the table can be found at

- <https://docs.kiln.fi/kiln-on-chain-v1/6eQVsijelOTzT9cvtG8s/>.

Severity Definitions

Smart Contracts severity levels

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood:high	Critical	High	Medium
Likelihood:medium	High	Medium	-
Likelihood:low	Medium	-	-

Critical: - Complete loss of funds or permanent freezing of funds

High: - Theft of unclaimed yield, commission/fees or Permanent freezing of unclaimed yield - Temporary freezing of funds > 2 days (excluding potential delay due to an oracle).

Medium: - Smart contracts inoperable due to lack of funds - Griefing or unbounded gas consumption

A PoC is required for the following severity levels:

- Smart Contract:
 - Critical
 - High
 - Medium

Rewards

Rewards for Smart Contract Bugs

Severity	Reward Amount
Critical	\$1,000,000
High	\$100,000
Medium	\$20,000

Reward Levels

- **Critical:** Upto 1,000,000, Minimum payout 100,000 Rewards will be further capped at 10% of direct funds at risk based on the valid POC provided
- **High:** Upto 100,000, Minimum payout 20,000 Rewards will be further capped at 100% of direct funds at risk based on the valid POC provided. In case of a temporary freeze of funds, reward is proportional to the amount of funds locked and increases as the freeze duration increases up until the maximum cap of the High severity levels.
- **Medium:** Upto 20,000, Minimum payout \$5,000 Rewards will be further capped at 100% of direct funds at risk based on the valid POC provided.
- The bug bounty will have a hard cap of \$1,500,000. In the case of multiple bug findings are submitted that exceed this amount, the rewards will be distributed on a first come first served basis.

Out of Scope

These impacts are out of scope for this bug bounty program. **General:**

- Consequences resulting from exploits the reporter has already carried out, which lead to damage.
- Issues caused by attacks that require access to leaked keys or credentials.
- Problems arising from attacks that need access to privileged roles (e.g., governance or strategist), except when the contracts are explicitly designed to prevent privileged access to functions that enable the attack.
- Issues relying on attacks triggered by the depegging of an external stablecoin, unless the attacker causes the depegging due to a bug in the code.
- References to secrets, access tokens, API keys, private keys, etc., that are not being used in production.

Smart Contracts:

- Issues arising from incorrect data provided by third-party oracles, with the exception of oracle manipulation or flash loan attacks.
- Attacks that rely on basic economic or governance vulnerabilities, such as a 51% attack.
- Problems related to insufficient liquidity.
- Issues stemming from Sybil attacks.
- Concerns involving risks of centralization.
- Suggestions for best practices.

Roles:

- Operator, Admin and Proxy Admin are trusted to behave properly and in the best interest of the users. They should not be considered as malicious. Submission citing malicious behaviour of these

roles will be considered invalid.

Known Issues

Known issues listed and acknowledged below are not eligible for any reward through the bug bounty program.

- <https://kilnfi.notion.site/EXTERNAL-AUDITS-479819dce90540d1a0800c0541d2352b>

Specific Types of Issues

- Informational findings.
- Design choices related to protocol.
- Issues that are ultimately user errors and can easily be caught in the frontend. For example, transfers to `address(0)`.
- Rounding errors.
- Relatively high gas consumption.
- Extreme market turmoil vulnerability.

Disclosure

Researchers who submit valid vulnerability reports agree to adhere to the following responsible disclosure process:

- Upon confirmation of a valid vulnerability, Kiln will work diligently to develop and implement a fix.
- Once the fix is deployed to production, Kiln will notify the researcher and initiate a 1-month (30 calendar days) disclosure waiting period.
- During this waiting period, the researcher must maintain strict confidentiality regarding the vulnerability and shall not disclose any information about it to third parties or the public.
- After the 1-month period has elapsed following the production deployment of the fix, the researcher may publicly disclose the vulnerability, provided they have obtained written approval from Kiln regarding the content of the disclosure.
- The researcher agrees to coordinate with Kiln on the timing and content of any public disclosure to ensure all parties are prepared and to minimize potential risks to users.
- If the researcher discovers that the vulnerability has become publicly known before the end of the waiting period, they should immediately notify Kiln. Kiln reserves the right to request an extension of the waiting period in exceptional circumstances, which will be communicated to the researcher in writing.

KYC

The following information is required for payments:

- If the claim comes from an individual:
 - The first names, surnames, date and place of birth of the person concerned
 - A Valid ID
- If the claim comes from a business:
 - Legal form, name, registration number and address of the registered office
 - Valid certificate of incorporation
 - List of shareholders/directors

Eligibility

Security researchers who fall under any of the following are ineligible for a reward

- Any person included on the List of Specially Designated Nationals and Blocked Persons maintained by the US Treasury Department's Office of Foreign Assets Control (OFAC) or on any list pursuant to European Union (EU) and/or United Kingdom (UK) regulations.

Prohibited Actions

- Live testing on public chains, including public mainnet deployments and public testnet deployments.
 - We recommend testing on local forks, for example using foundry.
- Public disclosure of bugs without the consent of the protocol team.
- Any denial of service attacks that are executed against project assets
- Automated testing of services that results in a denial of service
- *Conflict of Interest*: any employee or contractor working with Project Entity cannot participate in the Bug Bounty.
- Attempting phishing or other social engineering attacks against our employees and/or customers

© 2026 Cantina. All rights reserved.

[Terms of Use](#)

[Privacy Policy](#)

[Contact Form](#)

[Support](#)

Security Contact

Status

